W01 Quality Risk Cards

ENGSE601 · THE ONE Bakery · TeamName: TheOneBakery · 3 risk cards + source/evidence status

ขอบเขต: ใช้ข้อมูลจาก S1-B และ source code ของโครงงานที่เปิดตรวจได้เท่านั้น เอกสาร Proposal/SRS ที่อนุมัติและ version ของ requirement ยังไม่ปรากฏใน repo จึงต้องคง source gap เป็น Not Ready; code findings ด้านล่างเป็น static review ไม่ใช่ผล runtime.

Context and source register

รายการ	ข้อมูล
Team / Project	TheOneBakery / THE ONE Bakery
Critical slice	การบันทึกคำสั่งซื้อและคำนวณยอดรวม
Primary sources	S1-B ของทีม; public source repository: https://github.com/Nanthawat67/the-one-bakery-New (main), โดยเฉพาะ routes/orders.js, database/schema.sql และ README-FIX12.md
Evidence status	Source/code: Existing; approved Proposal/SRS: Not Ready; API/DB/System runtime: Not Executed

QR-01 · ความถูกต้องของจำนวนสินค้าและยอดรวม

หัวข้อ	บันทึกความเสี่ยง
Source / fact	S1-B ระบุว่าระบบต้องบันทึกคำสั่งซื้อและคำนวณยอดรวมให้ถูกต้อง; routes/orders.js อ่านราคาจาก products แล้วคำนวณ total ฝั่ง server; order_items.quantity เป็น INT ใน database/schema.sql.
Risk statement	หาก API ไม่ตรวจรูปแบบ quantity อย่างชัดเจน หรือมีรายการ/ราคาที่ไม่ตรงกัน ยอดรวมอาจผิดหรือการบันทึกอาจล้มเหลว และผู้ใช้ไม่ทราบเหตุผลที่ชัดเจน.
Quality concern / impact	Functional correctness, reliability และความถูกต้องของข้อมูลทางการเงิน.
Verification action	บน test DB ทดสอบสินค้า active, หลายรายการ, quantity = 1, 0, -1 และ 1.5; ตรวจ HTTP response, orders, order_items และ total ก่อน/หลัง.
Validation action	ให้ผู้ใช้ตัวแทนตรวจยอดในตะกร้า/คำยืนยันเทียบกับข้อมูลออเดอร์ที่บันทึกจริง.
Evidence status / next action	โค้ดอ้างอิงมีอยู่; การรัน API/DB ยัง Not Executed. ยืนยัน expected rules กับผู้รับผิดชอบ requirement และเก็บ output จากการรันจริง.

QR-02 · ความครบถ้วนของสูตรวัตถุดิบและการตัด stock

หัวข้อ	บันทึกความเสี่ยง
Source / fact	README-FIX12.md อธิบายการตัด stock เมื่อผลิตเสร็จ/ส่ง Packing; routes/orders.js มี consumeInventoryForOrder; schema มี recipes, inventory และ inventory_movements.
Risk statement	ถ้าสินค้าที่เปิดขายไม่มี recipe หรือหน่วย/ปริมาณในสูตรไม่ตรงกับ stock ระบบอาจเปลี่ยนสถานะได้โดยไม่มี movement ครบ ทำให้ stock ในระบบไม่ตรงกับการผลิตจริง.
Quality concern / impact	Data integrity และความน่าเชื่อถือของการวางแผนผลิต/วัตถุดิบ.
Verification action	เทียบ active products กับ recipes; ทดสอบ stock พอ/ไม่พอ, transaction rollback และการกดผลิตเสร็จซ้ำ; ตรวจ inventory ก่อน-หลังและ movement rows.
Validation action	ให้ผู้ดูแลวัตถุดิบเทียบยอดคงเหลือที่ระบบรายงานกับข้อมูลทดสอบที่ทราบค่าคาดหวัง.
Evidence status / next action	โค้ดและ design note: Existing; coverage/หน่วยสูตรและ DB run: Not Executed. ต้องทดสอบบน test DB และบันทึกค่าจริง.

การจัดการความเสี่ยงนี้ต้องไม่ถือว่าผ่านจากการอ่านโค้ดเพียงอย่างเดียว เพราะยังไม่มีหลักฐานจากฐานข้อมูลทดสอบ.

QR-03 · การอนุญาตให้ยกเลิกออเดอร์

หัวข้อ	บันทึกความเสี่ยง
Source / fact	ใน routes/orders.js มี POST /:id/cancel; จาก route/handler ที่ตรวจ ไม่เห็น auth middleware หรือ ownership check ชัดเจน. ยังไม่พบ formal security requirement ที่อนุมัติ.
Risk statement	ผู้เรียกที่ทราบหรือเดา order ID อาจพยายามยกเลิกออเดอร์ที่ไม่ใช่ของตน หากไม่มีการตรวจสิทธิ์ฝั่ง server. นี่เป็นข้อสังเกตจาก static review ไม่ใช่การพิสูจน์ exploit.
Quality concern / impact	Security/authorization และความต่อเนื่องของการรับออเดอร์.
Verification action	หลังผู้รับผิดชอบยืนยันกฎสิทธิ์ ให้ทดสอบไม่มี credential, owner ผิด, owner ที่ได้รับอนุญาต และการยกเลิกหลังเริ่มผลิต; ตรวจ status/history ก่อน-หลัง.
Validation action	ยืนยันกับเจ้าของร้านว่าผู้ใดมีสิทธิ์ยกเลิกและยกเลิกได้ถึงสถานะใด.
Evidence status / next action	ข้อสังเกตจาก source: Existing; security/runtime test: Not Executed; owner decision: Not Ready. ห้ามสรุปว่าเป็นช่องโหว่ที่ยืนยันแล้วจนกว่าจะทดสอบ/ทบทวนจริง.

Handoff and team check

Check item	Current evidence / follow-up
Trace to source	อ้าง S1-B และไฟล์ source code; ก่อนส่งให้ระบุ exact branch/commit ที่ทีมใช้ตรวจ.
Quality Risk Cards	มี 3 cards พร้อม event/impact, quality concern, Verification/Validation และ evidence status.
Peer review	ยังไม่บันทึกผล peer review — ผู้ใช้ให้เพื่อนตรวจจริงและเติมชื่อ/วันที่/ข้อเสนอ/การแก้ไขใน repository.
Formal requirements	Proposal/SRS/version ที่อนุมัติยัง Not Ready; อย่าสร้าง requirement ID หรือ stakeholder decision ขึ้นเอง.

AI use: ใช้ AI ช่วยจัดโครงสร้างและสรุปข้อเสนอจาก worksheet/source paths; ทีมต้องตรวจ ยอมรับ/แก้/ปฏิเสธและบันทึกจริงใน AI-LOG.md. ไม่มีการสร้างผลทดสอบหรือภาพหลักฐานด้วย AI.